

		Jurusan Teknologi Informasi Politeknik Negeri Malang		JOBSHEET 03	
		Jobsheet Minggu-3: Secure Design & Secure Coding		Pertemuan 3	
		Mata Kuliah: Keamanan Sistem Informasi Pengampu: Ade Ismail, S.Kom., M.TI		Semester 6	
				Waktu: 2 Jam	
Nama	Muhammad Zikri		NIM	243107040035	
Kelas	2B_Teknologi Informasi		Tgl	11 Februari 2026	

1 Topik

Pertemuan ketiga ini berfokus pada penerapan mekanisme pengamanan sistem melalui fase perancangan (*Secure Design*) dan prinsip pengkodean yang aman (*Secure Coding*). Fokus utama adalah bagaimana membangun keamanan sejak awal siklus pengembangan untuk meminimalisir celah keamanan pada sistem informasi.

2 Tujuan Pembelajaran (Sub-CPMK 05.3.1)

Setelah menyelesaikan modul praktikum ini, mahasiswa diharapkan:

1. Mampu menjelaskan konsep *Secure Design* dan filosofi *Building Security In* dalam pengembangan perangkat lunak.
2. Mampu mengidentifikasi prinsip-prinsip desain aman seperti *Least Privilege*, *Defense in Depth*, dan *Fail-Safe Defaults*.
3. Mampu merancang skema alur proses sistem informasi yang meminimalisir celah keamanan melalui teknik validasi input dan sanitasi data.

3 Landasan Teori

3.1 Secure Design: Building Security In

Berdasarkan konsep dari Gary McGraw, keamanan bukanlah fitur yang ditambahkan setelah aplikasi selesai dibuat, melainkan harus diintegrasikan sejak tahap desain. Desain yang aman bertujuan untuk mengurangi permukaan serangan (*attack surface*) dan memastikan sistem tetap tangguh meskipun terjadi kegagalan fungsi.

3.2 Prinsip Dasar Desain dan Coding Aman

Beberapa prinsip krusial dalam perancangan sistem informasi yang aman meliputi:

- **Least Privilege** : Memberikan hak akses paling minimal yang dibutuhkan oleh pengguna atau proses untuk menjalankan tugasnya.
- **Defense in Depth** : Menerapkan mekanisme pertahanan berlapis sehingga jika satu lapis keamanan ditembus, masih ada lapis pertahanan lainnya.
- **Input Validation** : Proses krusial dalam *Secure Coding* untuk memastikan semua data yang masuk ke sistem telah diperiksa integritasnya guna mencegah serangan seperti SQL Injection dan XSS.

4 Alat dan Bahan

- Perangkat Keras: Laptop/PC dengan akses internet.
- Perangkat Lunak: Browser, Aplikasi pembuat diagram (*Draw.io*, *Visio*, atau sejenisnya), LMS Polinema.

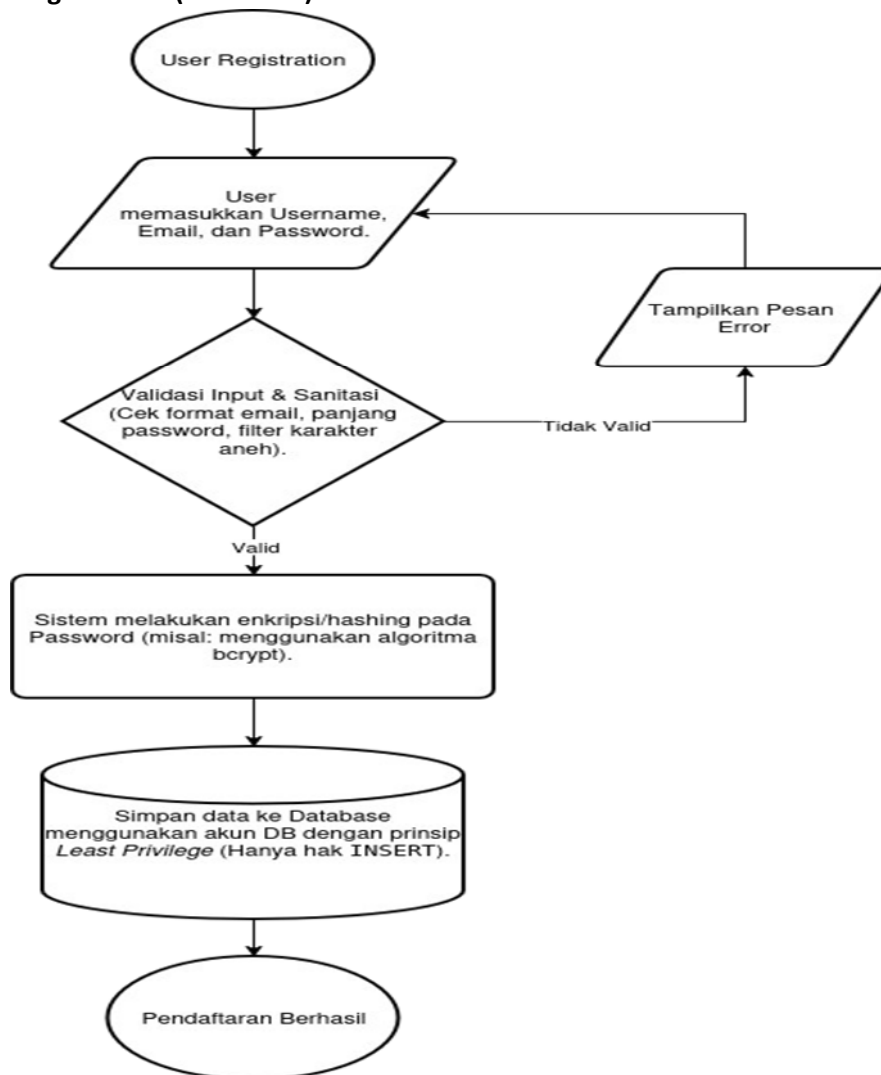
5 Langkah Kerja

1. Lakukan diskusi bersama kelompok untuk menentukan satu alur proses bisnis aplikasi (contoh: Alur Pendaftaran Pengguna atau Alur Transaksi Pembayaran).
2. Identifikasi potensi ancaman keamanan yang mungkin terjadi pada setiap titik alur tersebut (misalnya: manipulasi data input atau akses ilegal).
3. Tentukan titik-titik pengecekan keamanan (*security checkpoints*) yang harus ada dalam desain alur tersebut berdasarkan prinsip *Least Privilege* dan *Input Validation* .

6 Tugas Praktikum (Kelompok)

Susunlah laporan mandiri hasil perancangan desain aman dengan ketentuan sebagai berikut:

1. Diagram Alur (Flowchart) :



2. Analisis Mitigasi,

Diagram alur di atas dirancang untuk memitigasi risiko keamanan berikut:

- **Mitigasi Injeksi Data (SQL Injection & XSS):** Risiko penyerang memasukkan skrip berbahaya (XSS) atau memanipulasi *query* database (SQL Injection) dimitigasi pada tahap **"Validasi Input & Sanitasi"** . Sistem memastikan bahwa semua data yang masuk diperiksa integritasnya, menolak format yang tidak sesuai, dan membersihkan karakter-karakter aneh sebelum diproses lebih lanjut.
- **Mitigasi Pencurian Kredensial:** Mitigasi ini dilakukan pada tahap **"Enkripsi/Hashing"** . Jika database berhasil diretas, penyerang tidak akan mendapatkan *password* asli pengguna

karena data telah diacak menggunakan algoritma *hashing* (seperti bcrypt), sehingga mencegah pengambilalihan akun.

- **Mitigasi Eskalasi Hak Akses (Privilege Escalation):** Pembatasan ini terjadi di tahap "**Penyimpanan Database**". Dengan membatasi hak akses akun database hanya untuk `INSERT`, penyerang yang berhasil menyusup melalui form pendaftaran tidak akan bisa menghapus (`DELETE`) atau mengubah (`UPDATE`) data tabel lain di dalam sistem.

3. **Penerapan Prinsip**, Rancangan alur ini menerapkan filosofi *Building Security In*, di mana keamanan diintegrasikan sejak tahap desain. Prinsip-prinsip yang digunakan meliputi:

- **Input Validation:** Diterapkan di awal proses untuk memastikan semua data yang masuk ke sistem telah diperiksa integritasnya guna mencegah serangan injeksi. Alasannya adalah *input* dari pengguna merupakan titik masuk (*entry point*) paling rawan dalam sebuah aplikasi.
- **Least Privilege:** Memberikan hak akses paling minimal yang dibutuhkan oleh proses. Diterapkan pada saat menyimpan data ke database, di mana akun yang digunakan aplikasi untuk mendaftar *user* baru hanya dibekali izin `INSERT`, tanpa izin administratif lainnya.
- **Defense in Depth:** Menerapkan mekanisme pertahanan berlapis. Alur ini tidak hanya mengandalkan satu lapis keamanan (seperti validasi input saja). Jika validasi input berhasil dijawab, masih ada pertahanan lapis kedua (*hashing password*) dan lapis ketiga (pembatasan hak akses database) yang melindungi sistem.

7 Pengumpulan Tugas

- Format laporan: PDF.
- Nama file: **[JS03]NoAbsen NamaLengkap.pdf**.
- Unggah melalui LMS Polinema sebelum batas waktu yang telah ditentukan.